GWENDAL LE COGUIC

FORMATIONS

Chaque formation est axée sur des démonstrations pratiques, des exercices interactifs et des discussions sur des situations réelles afin de garantir l'acquisition de compétences clés.

Chaque session peut être suivie :

- sur site ou à distance
- en français ou en anglais
- individuellement ou en groupe

Devis sur demande

Tel: +33 7 69 02 25 10
Email: contact@glc.st

SÉCURITÉ LARAVEL



a. Description

*Cette formation d'une journée est destinée aux **développeurs Laravel** qui souhaitent créer des applications sécurisées de A à Z. Vous apprendrez à **identifier les vulnérabilités courantes**, à **appliquer les protections intégrées de Laravel** et à **adopter les meilleures pratiques** pour sécuriser l'**authentification**, l'**autorisation**, la **validation des entrées**, et bien plus encore.*

b. Objectifs pédagogiques

- Reconnaître les vulnérabilités web courantes et les protections de Laravel
- Implémenter une authentification et une autorisation sécurisées avec les outils Laravel
- Configurer correctement les protections CORS et CSRF
- Valider et nettoyer les entrées utilisateur de manière sécurisée
- Gérer les uploads et le stockage de fichiers en toute sécurité

c. Pré-requis

- Bonne expérience avec PHP et le framework Laravel
- Compréhension des concepts de sécurité des applications web
- Familiarité avec les vulnérabilités web de base (XSS, CSRF, SQLi…)

d. Public cible

- Développeurs Laravel
- Professionnels de la sécurité
- Ingénieurs Dev(Sec)Ops

e. Programme

Configuration globale

- Sécurité PHP de base
- Configuration globale
- Sessions
- *APP_KEY*

Les bases

- PHP brut dans les vues
- Validation des entrées
- Journalisation et gestion des erreurs
- Mises à jour et sauvegardes
- Tromper les robots

Cookies et sessions

- Configuration globale
- Configuration spécifique à Laravel
- Fixation de session

Mots de passe et chiffrement

- Chiffrer/déchiffrer les données
- Validation des mots de passe
- Réinitialiser les mots de passe

Authentification et permissions

- Packages officiels
- Laravel Passeport
- Gates et Policies
- Utilisateurs / rôles / permissions

Rate limiting

- Utilisation de base
- Limiter les actions / routes

Téléchargement et stockage de fichiers

- Qu'est-ce que c'est ?
- Règles de validation et nettoyage
- Configuration et utilisation des stockages
- Autorisations / permissions / visibilité

Affectation de masse

- Qu'est-ce que c'est ?
- Attentes vs. réalité
- Comment se protéger

Exposition excessive des données

- Qu'est-ce que c'est ?

- Comment se protéger
- Ce qu’il faut retenir

Injection SQL (SQLi)

- Qu'est-ce que c'est ?
- Requêtes préparées
- Paramètres liés
- Les dangers
- Ce qu’il faut retenir

Cross-Site scripting (XSS)

- Qu'est-ce que c'est ?
- Contrôleurs
- Modèles
- Nettoyage des entrées
- Aides externes

Cross-Site Request Forgery (CSRF)

- Qu'est-ce que c'est ?
- Jeton anti-CSRF
- Middleware
- Formulaires
- *X-csrf-token* et *X-xsrf-token*

Cross origin resources sharing (CORS)

- Qu'est-ce que c'est ?
- Configuration
- *allowed_origins* et *supports_credentials*